

Apart from the above, there are many other files which should not be disclosed publicly, such as temporary files, renamed old files, user's private home folders, etc. Now, the question is regarding how attackers can gain access to directory listings. I am not going the route of guessing the path of a crucial directory via URI. For this, attackers can simply use Google's advanced search operators (now it's obviously a pre-requisite to know Google's advanced search operators, 'site:', 'inurl:', 'intext:', 'intitle:', etc).



Note: I once again stress that neither LFY nor I are responsible for the misuse of the information given in this article. The attack techniques are meant to give you the knowledge that you need to protect your own infrastructure. You will be held solely responsible for any misuse of this knowledge.

Google searches for directory listings

Searching for `intitle:index.of site:example.com` will give you the directory listing of `example.com` if the directory listing is enabled on the server—and in most cases, it is. Such a result may contain any of the above crucial files. Similarly, searching for `intitle:index.of ws_ftp.log` or `intitle:index.of 'parent directory' 'ws_ftp.ini'` will return directory listings that contain the files `ws_ftp.log` or `ws_ftp.ini`. In the same manner, attackers can also search for `.bak`, `.bnp`, `.swp` and other vulnerable extensions and files.

Another popular query among attackers is `site:example.com AND intitle: 'index.of' 'backup'` which yields the `backup` directory (if it exists on the `example.com` domain). A similar query, `site:example.com AND ext:log`, will yield all the log files on the domain.



Note: The AND boolean operator combines two or more conditions in the same query.

Another such query is "`robots.txt`"

+ "`Disallow:`" `ext:txt site:example.com`. This yields the `robots.txt` file for `example.com`, which tells the attacker about paths and directories that the website admin doesn't want Google's spider to crawl.

A more dangerous query is "`phpMyAdmin`" "`running on`" `inurl: "main.php"`, which leads attackers straight to the `phpMyAdmin` page on the server—one of the worst nightmares of an administrator. If you try this out, please don't click through to any of the many results!

Other useful trial queries that you can guess the purpose of, are:

- `intitle:index.of.password`
- `intitle:"Index of" _vti_inf.html`
- `allinurl:auth_user_file.txt`
- `allinurl:admin mdb`
- `site:edu filetype:xls +bank account`
- `filetype:bak inurl:"htaccess[password/shadow]users"`

The story does not end here... there are many more queries that can be generated and tested.

Time for security

Information leakage via directory listing and Google is a big issue, and also requires almost no expertise; hence, it falls in the category of dangerous vulnerabilities. You can follow these security steps to safeguard yourself:

1. Putting in blank `index.htm` files simply prevents directory listings from being displayed to site visitors. Add some text like, "Your access has been logged" if you wish to fool script kiddies.
2. To disable directory listing in Apache, open the `.htaccess` file and look for `Options Indexes` under the directory you want to disable, and modify it to `Options -Indexes`. Do the same in your `httpd.conf` file, and then restart Apache. Directory listing should be disabled now.
3. If you need to keep listing enabled, then do not link any files that may provide crucial information to attackers.
4. It's a common misconception that

ELECTROMECH CORPORATION

RHCE / RHCVA / RHCSS Training
Training by experts



RHCE Exam

28th March 2011

RHCSS RH423

28th March 2011

RHCSS RH333

28th March 2011

Ahmedabad, Baroda, Rajkot - Gujarat

**"Come home of
Open Source"**



**Redhat Channel Partner
and Training Partner**

Ahmedabad:

404, Maulik Arcad, Nr. Mansi
cross Road, Satellite Rd

Baroda:

25, The Emperor, Fatehgunj

Ph.: 079 40027898/9327218003/
9327247499, Rajkot: 09427576240

Http://www.electromech.info
E-mail: electromech@electromech.info